

IFRAME INTEGRATION API

Iframe Integration API

Embed the AdvantageClub.ai rewards marketplace with seamless auto-login.

BASE URL

api.advantageclub.ai

AUTH

2-Step JWT Bearer

PROTOCOL

HTTPS · TLS 1.2+

FORMAT

REST · JSON

Auth Flow

Token → Link → Iframe

Token TTL

180s JWT · 300s Link

Support

product@advantageclub.ai

Overview

The AdvantageClub.ai Iframe Integration API provides a secure two-step authentication flow that lets your application embed the rewards marketplace in an iframe. Users are auto-authenticated — no separate login screen required.



Server-side only: All API calls must originate from your backend. Never expose `client_secret` in frontend code, mobile apps, or browsers.



For: Engineering teams integrating the AdvantageClub.ai marketplace within HR portals, intranets, or mobile apps for employee rewards.



Credentials: Your `client_id` and `client_secret` will be shared separately by the AdvantageClub.ai team prior to integration.

Base URL & Environments

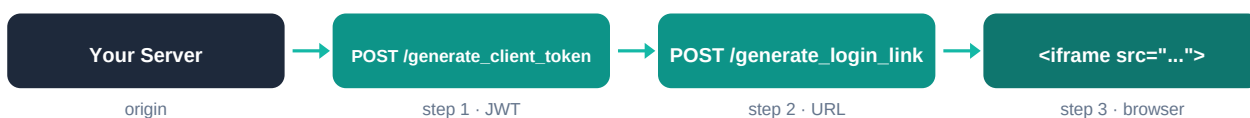
Environment	Base URL	Notes
Production	https://api.advantageclub.ai/api/v1	Live environment. Real credentials.
Sandbox	https://sandbox-api.advantageclub.ai/api/v1	Integration testing. Test credentials.
Staging	https://staging-api.advantageclub.ai/api/v1	Pre-release. Access on request.



All environments require HTTPS. HTTP requests are rejected. TLS 1.2+ required.

Authentication Flow

Steps 1 and 2 run on your server. Step 3 renders in the browser.



JWT token expires in 180 seconds. Auto-login link expires in 300 seconds. Generate both as close to user page-load time as possible.

● Endpoint 1 — Generate Authentication Token

POST /api/v1/generate_client_token

Authenticates your application using client_id and client_secret. Returns a short-lived JWT for use in Step 2.

Request Headers

Parameter	Type	Description
Content-Type	string	application/json
X-Request-ID	string	Optional. UUID for request tracing.

Request Body Parameters (* required)

Parameter	Type	Description
client_id *	string	Unique client identifier. Credentials will be shared separately.
client_secret *	string	Secret key paired with client_id. Never expose client-side.
user_identifier *	string	Unique user ID — employee ID, email, or UUID.

Request Example

JSON · REQUEST BODY

```
{
  "client_id":      "ac_client_prod_a1b2c3d4",
  "client_secret":  "sk_prod_XXXXXXXXXXXXXXXXXXXX",
  "user_identifier": "EMP-932412383"
}
```

Success Response — 200 OK

JSON · 200 OK

```
{
  "success":      true,
  "token":        "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "expires_in":   180,
  "token_type":   "Bearer"
}
```

Parameter	Type	Description
token	string	JWT. Use as Bearer token in Step 2 Authorization header.
expires_in	integer	Seconds until token expires. Default 180s. Do not cache.

Parameter	Type	Description
token_type	string	Always 'Bearer'.

Error Responses — Endpoint 1

HTTP	Error Code	Description	Action
400	MISSING_PARAMETERS	Required fields absent.	Check all fields are present.
401	INVALID_CREDENTIALS	client_id or secret wrong.	Credentials will be shared separately.
429	RATE_LIMIT_EXCEEDED	Too many requests in window.	Respect Retry-After header.
500	INTERNAL_SERVER_ERROR	Unexpected server error.	Retry. Contact support if persists.

● Endpoint 2 — Generate Auto Login Link

POST /api/v1/generate_login_link

Exchanges the Bearer token for a one-time auto-login URL. Load this URL in an iframe to authenticate the user without a separate login.

Request Headers

Parameter	Type	Description
Authorization	string	Bearer <token> — JWT from Step 1.
Content-Type	string	application/json
X-Request-ID	string	Optional. UUID for request tracing.

Request Body Parameters (* required)

Parameter	Type	Description
user_identifier *	string	Must match the identifier used in Step 1.
name	string	Optional. User display name for page personalisation.
redirect_path	string	Optional. Deep-link path. Default: pages/rewards_home.

Request Example

JSON · REQUEST BODY

```
{
  "user_identifier": "EMP-932412383",
  "name": "Sarah Johnson",
  "redirect_path": "pages/rewards_home"
}
```

Success Response — 200 OK

JSON · 200 OK

```
{
  "success": true,
  "data": { "user_identifier": "EMP-932412383" },
  "redirect_url": "https://app-sso.advantageclub.ai/signin?token=cc0901fc...",
  "link_expires_in": 300
}
```

! redirect_url is single-use and expires in 300 seconds. Do not cache or reuse. Generate a fresh link per page load.

Error Responses — Endpoint 2

HTTP	Error Code	Description	Action
401	INVALID_TOKEN	Bearer token invalid/expired.	Re-run Step 1 for fresh token.
403	USER_DISABLED	User account is deactivated.	Contact AdvantageClub.ai support.
404	USER_NOT_FOUND	No user matches the identifier.	Verify user is registered.
429	RATE_LIMIT_EXCEEDED	Too many requests.	Respect Retry-After header.
500	INTERNAL_SERVER_ERROR	Unexpected server error.	Retry with backoff.

● Iframe Embed Guide

1 Fetch the auto-login URL server-side

Call both endpoints in sequence on your backend when the user navigates to the rewards page. Return only the `redirect_url` to the client.

JAVASCRIPT · EXPRESS.JS ROUTE

```
app.get('/rewards-url', authenticate, async (req, res) => {
  const { token } = await getClientToken(req.user.id); // Step 1
  const { redirect_url } = await getLoginLink(token, req.user); // Step 2
  res.json({ url: redirect_url }); // Return only the URL
});
```

2 Embed with recommended iframe attributes

Always set `sandbox` and `referrerpolicy`. Adjust height as needed.

HTML · RECOMMENDED IFRAME ATTRIBUTES

```
<iframe
  id="ac-rewards-frame"
  src=""
  width="100%" height="700px"
  style="border:none; border-radius:12px;"
  sandbox="allow-scripts allow-same-origin allow-forms allow-popups"
  referrerpolicy="strict-origin-when-cross-origin"
  loading="lazy" title="AdvantageClub Rewards"
></iframe>
```

3 Add Content Security Policy headers

Required for the iframe to render. Add to your server response headers.

HTTP · RECOMMENDED CSP HEADER

```
Content-Security-Policy:
  frame-src https://*.advantageclub.ai;
  connect-src https://api.advantageclub.ai;
```

4 Handle session lifecycle via `postMessage`

Listen for `postMessage` events from the iframe to handle expiry and navigation.

JAVASCRIPT · POSTMESSAGE LISTENER

```
window.addEventListener('message', (event) => {  
  if (event.origin !== 'https://app-sso.advantageclub.ai') return;  
  const { type, payload } = event.data;  
  if (type === 'SESSION_EXPIRED')    loadRewards();  
  if (type === 'REDEMPTION_COMPLETE') showSuccessToast(payload.message);  
  if (type === 'RESIZE')             frame.style.height = payload.height+'px';  
});
```


● Session Lifecycle

Object	TTL	On Expiry
Client Token (JWT)	180s	API returns 401 INVALID_TOKEN. Re-run Step 1.
Auto Login Link	300s	URL invalid. Listen for SESSION_EXPIRED postMessage.
Iframe Session	~30 min	Re-run full 2-step flow; reload iframe src attribute.

I Best practice: Generate redirect_url fresh on every page load. The full two-step flow typically completes in under 300ms.

● Security Best Practices

Credential Protection

- Store client_secret in env variables only
- Never log credentials in API responses
- Rotate secrets every 90 days
- Use separate credentials per environment

Iframe Sandbox

- Always set the sandbox attribute
- Allow: scripts, same-origin, forms, popups
- Set referrerpolicy to strict-origin
- Validate event.origin on all postMessages

Transport Security

- HTTPS only — TLS 1.2+ required
- Set Strict-Transport-Security header
- Add X-Frame-Options: SAMEORIGIN
- Enforce CSP frame-src allowlist

API Access Control

- Whitelist server IP with AdvantageClub.ai
- Use exponential backoff on 429 responses
- Log errors with X-Request-ID for tracing
- Alert on repeated 401s (credential leak)

● Rate Limits

Limits apply per client_id on a rolling 60-second window.

100

req / min

/generate_client_token

300

req / min

/generate_login_link

1,000

req / min

global per client_id

50k

req / day

default daily cap

Rate Limit Response Headers

Parameter	Type	Description
X-RateLimit-Limit	integer	Max requests allowed in the rolling window.
X-RateLimit-Remaining	integer	Requests remaining in the current window.
X-RateLimit-Reset	integer	Unix timestamp when the window resets.
Retry-After	integer	Seconds to wait before retrying (429 only).

Retry Strategy — Exponential Backoff

JAVASCRIPT · EXPONENTIAL BACKOFF

```
async function fetchWithRetry(url, options, maxRetries = 3) {
  for (let attempt = 0; attempt < maxRetries; attempt++) {
    const res = await fetch(url, options);
    if (res.status !== 429) return res;
    const wait = (res.headers.get('Retry-After') || 2 ** attempt) * 1000;
    await new Promise(r => setTimeout(r, wait));
  }
  throw new Error('Max retries exceeded');
}
```

● Complete Error Code Reference

HTTP	Error Code	Description	Action
400	MISSING_PARAMETERS	Required fields absent from body.	Check all required params are present.
401	INVALID_CREDENTIALS	client_id or client_secret wrong.	Credentials will be shared separately.
401	INVALID_TOKEN	Bearer token invalid or malformed.	Re-run Step 1 to get a fresh token.
401	TOKEN_EXPIRED	Token exceeded 180s TTL.	Do not cache tokens. Re-run Step 1.
403	USER_DISABLED	User account is deactivated.	Contact AdvantageClub.ai support.
404	USER_NOT_FOUND	No user matches the identifier.	Verify user is registered on platform.
429	RATE_LIMIT_EXCEEDED	Too many requests in current window.	Read Retry-After header and wait.
500	INTERNAL_SERVER_ERROR	Unexpected server-side error.	Retry with backoff. Contact support.

● Changelog

Parameter	Type	Description
v1.0.0	2024-01-01	Initial release: token generation, login link, iframe embed.